

CSIT302 Cybersecurity

Day 2-1 – Reconnaissance and Compromising the System (1)

Subject Coordinator: Dr Partha Sarathi Roy
School of Computing and Information Technology

Reconnaissance



UNIVERSITY
OF WOLLONGONG
AUSTRALIA

This slide is copyrighted. It must not be distributed without permission from UOW

Reconnaissance



- Reconnaissance is a term used widely in the military operation.
 - The literal meaning is “sending spies into an enemy's territory to gather data about where and when to strike”.
- If reconnaissance is done right, the target will not be able to know that it has been performed.

Reconnaissance (In Cybersecurity)

- Reconnaissance is one of the most important stages of an attack life cycle.
- Attackers *search for vulnerabilities* that they can use to attack targets.
- An attacker will be interested in *locating and gathering data*, and *identifying any loopholes* in a target's network, its users, or its computing systems.
- There are two types: External and internal reconnaissance. (Our main focus is external one.)

(External) Reconnaissance

Compromising System

Lateral Movement

Privilege Escalation

Concluding the mission

External Reconnaissance

External Reconnaissance

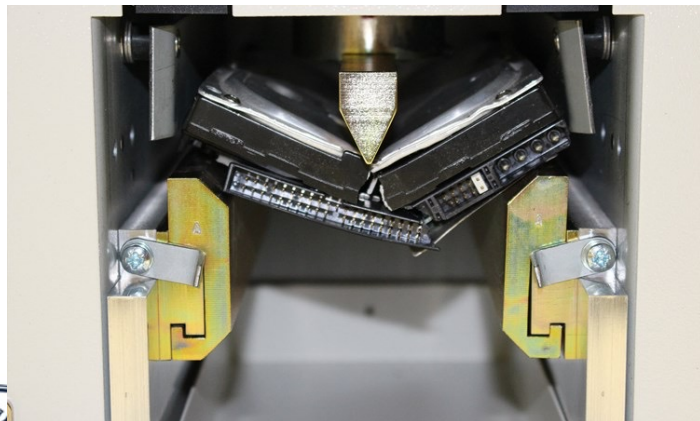
- External reconnaissance is done *outside of the organization's* network and systems.
- It normally focuses on *exploiting the carelessness of users* of an organization.
- Possible ways to perform external reconnaissance is the following:
 - Dumpster diving
 - Social media
 - Social engineering

Dumpster Diving

- Organizations dispose of obsolete devices in a number of ways, such as through bidding, sending to recyclers, or dumping them in storage.
→ There are *serious implications* for these methods of disposal.
- By taking old external storage devices or obsolete computers which are not thoroughly handled, attackers may get the information like
 - The internal setup of an organization
 - Openly-stored passwords on browsers
 - The privileges and details of different users
 - Access to some bespoke systems used in the network

Dumpster diving

- Example of thorough disposal: Google
 - The company destroys its old hard drives from its data centres to prevent the data that they contained from being accessed by malicious people.
 - The hard drives are put into a crusher that pushes steel pistons up the centre of the disks, rendering them unreadable.
 - <https://www.youtube.com/watch?v=4jNEwOhCFVg>



Dumpster Diving

- More general way to completely remove the data in the disks is **degaussing**
 - It is the process of reducing or eliminating an unwanted magnetic field (or data) stored on tape and disk media such as computer and laptop hard drives → *Does not work for SSD.*
 - *Deleting the data using software is generally not a secure way.*
- How to remove the data in the SSD:
 - There is no standard way for this.
 - One of the suggested way is encryption: *Encrypt* the disk with a long random key and forget the key. Then, format the disk.



Social Media

- Social Media
 - Social media are interactive computer-mediated technologies that facilitate the creation and sharing of information, ideas, career interests and other forms of expression via virtual communities and networks.
- It became the easiest way to find out a huge amount of information about people.
 - The *best place to mine data* concerning specific targets.
 - *Data related to the companies* where users work for.
 - Details about *family members, relatives, friends, and residence and contact information*.

Social Media

- While the technical revolution of Social Media during the past decade can be viewed as exciting and innovative, it also leaves us vulnerable, particularly to identity theft.
- Identity theft in social media
 - Easy to create a *fake account* bearing the identity of another person
 - All that is needed is access to some *pictures and up-to-date details* of the identity theft victim.
 - Using the fake account to the organisation's high level officials, the hacker requests
 - ✓ Network information and statistics from the IT department
 - ✓ Security Information of the Network

Social Media

- ***Hackers can guess passwords or answers to secret questions*** through the posts:
 - Accepting “connections” or “friendships” with people you are not familiar with in your everyday life can put you at risk.
 - User's date of birth, their parent's maiden name, names of the street that they grew up in, pet names, school names and etc.
- ***Put a phishing post up or message*** from unfamiliar people using the Social Media.
 - Those can be the attempts to install malwares in the target’s computer.

Social Media

- Some tips to ***protect identity*** in the age of social media (<https://securityintelligence.com/how-to-prevent-a-social-media-hack/>):
 - Create strong, multi-character passwords for your email and all apps on your phone, and remember to change them often.
 - When utilising apps, enter as little personal information as possible.
 - Be cautious about what you post online. Never use personal information such as your Social Security number, IC, *current address* or *telephone number*.
 - Make sure your privacy settings are set to the highest level. Check these settings often since they may be affected by upgrades.

Social Media

- Avoid downloading free applications for use on your social media profiles.
- Avoid accepting connections or friendships with people you are not familiar with.
- Verify any link sent to you was sent from your connection or friend.
- Google your own name, as well as any social media handles you utilize, to track any possible forged accounts.

Social Engineering

- One of *the most powerful reconnaissance acts*
 - A company cannot completely protect itself from this type of threat.
 - Something beyond the protection of security tools (Exploiting human nature).
- Humans are sympathetic, trusting of friends, show-offs, and obedient to higher authorities → Open to attacks through manipulation of the information.
- **Six levers** of social engineering are
 - Reciprocation, scarcity, consistency, liking, authority and validation.

Social Engineering

- Reciprocation

- A victim does something for a social media user who in turn feels the need to *reciprocate the favour*.
- It is part of human nature to feel *obligated to return a favour* to a person, and attackers have come to know and exploit this.

- Scarcity

- Threatening *a short supply of something* that the target is in need of.
- e.g. a trip package, a mega sale, or a new release of products.

- Consistency

- Humans tend to honour promises or get used to *the usual flow of events*.
- E.g. Attackers to clone the known vendor of a IT team and deliver malware-infected electronics.

Social Engineering

- Liking
 - Humans are more likely to *comply with the requests of people they like or those that appear attractive*. → Easy to win the compliance of targets.
- Authority
 - Commonly used lever that has a high success rate.
 - Generally, *humans are obedient to the authority* of those that are ranked above them even if they seem malicious.
 - E.g. asking to give login credentials or to send some sensitive data over unsecured channels.
- Validation
 - Humans will readily comply to and do something *if other people are doing the same* → do not want to be an odd one.

Social Engineering

- Popular types of social engineering attacks.
 - Pretexting
 - Diversion theft
 - Phishing
 - ✓ Phone Fishing (vishing)
 - ✓ Spear phishing
 - Baiting
 - Quid pro quo
 - Tailgating

Social Engineering

- Pretexting

- The construction of an *elaborate lie* that has been well-researched so as to appear legitimate to the target.
- Social engineers that use pretexting have honed the art of impersonating an *imaginary boss or other trusted individuals* in society, such as police officers, debt collectors, tax officials, clergy, investigators.

- Diversion theft

- Attackers persuade *delivery and transport companies* that their deliveries and services are requested elsewhere.

Social Engineering

- Phishing

- The oldest tricks that hackers have used over the years, but its success rate is still surprisingly high. A hacker sends emails to a target. It pretends to be a legitimate third-party organization.

- Examples of Phishing:

- A link leading to a malicious or fraudulent website is also attached. The attackers will have made a replica website, complete with logos and usual content, as well as a form to fill in with sensitive information.
 - Claiming a court order notice and ask the recipients to view more details. Upon clicking the link, the recipients installed malware on their computers that can be used for other malicious purposes.

Social Engineering

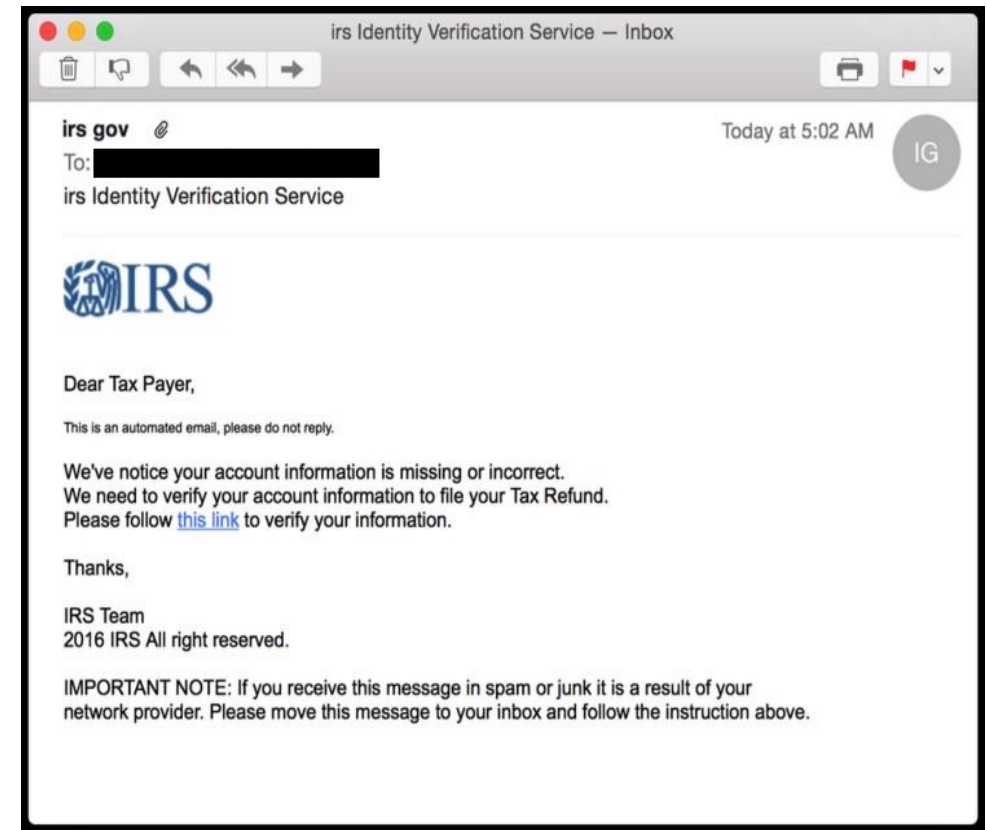
- Examples of Phishing:

- IRS refund

- ✓ Cyber attackers took advantage of the month of April, sent emails claiming to be from the IRS, attaching ransomware through a Word file.

- CareerBuilder

- ✓ Hackers pretended to be normal job applicants, but instead of attaching resumes they uploaded malicious files.
 - ✓ CareerBuilder then forwarded these CVs to multiple companies that were hiring.
 - ✓ Malware transferred to many organizations including police offices



Social Engineering

- Examples of Phishing:

- The following figure shows an example of a phishing email sent to a Yahoo user:



Phishing email

- The typical signs of Phishing emails include:
 - Ask for sensitive information
 - Use different domain
 - Contains a link that is not consistent with the domain
 - Is not personalized
 - Use poor spelling and Grammar
 - Always tries to panic the receiver
- Email is not completely secure!!!

Pshing Email

- How to stay safe?

- Think about before you click any link.
- Never provide your details via a link in a message
- Contact the person or business to check if they sent the message.
- Protect your computers via using security software
- Protect your account using multi-factor authentication
- ...

Social Engineering

- Phone phishing (vishing)
 - The attacker uses *phone calls* instead of emails or as an extension of the email phishing attack.
 - The attacker will use an illegitimate interactive voice response system that sounds exactly like the ones used by banks, service providers.
 - The target will be prompted by the system to give out some verification information. It is normal for the system to reject input that a target gives so as to ensure that several PINs are disclosed.
- Spear Phishing
 - Spear phishing is *specifically **targeted** to obtain information from particular end users* in an organization by performing a number of background checks on targets.
 - Statistically, normal phishing has a 3% success rate, whereas spear phishing has a **70% success rate**.

Social Engineering

- Water holing

- An attack strategy, ***in which the attacker guesses or observes which websites the group often uses and infects one or more of them with malware.***
- The victim is a particular group (organisation, industry or region).
 - ✓ The attacker may only attack users coming from a specific IP address.
 - ✓ The attacker may look for specific information.
 - ✓ Examples include NotPetya attack (attack on Ukrainian gov), attack on US department of labor.
- The specificity of the attack makes it harder to detect and research.
- The name is derived from predators in the natural world, who wait for an opportunity to attack their prey near watering holes.

Social Engineering

- Baiting

- Exploiting the greed or curiosity of a certain target.
- An attacker will ***leave a malware-infected external storage device*** in a place where other people can easily find it.
- Attackers are normally crafty and will leave files that a victim will be *tempted to open* such as "the executive summary of salaries and upcoming promotions"
- In more serious cases, attackers might install rootkit viruses in the thumb drive that infect computers when they boot, while an infected secondary storage media is then connected to them.
- Baiting has a high success rate because it is human nature to either be greedy or curious and open and read files that are above their level of access.

Social Engineering

- Quid pro quo (*a favour or advantage granted in return for something.*)
 - It is commonly carried out by low-level attackers.
 - Attackers will keep calling random numbers claiming to be from technical support, and will offer some sort of assistance, which then gives the attackers access to the victims' computers or the ability to launch malware.
 - This has a very low success rate.
- Tailgating
 - The least common social engineering attack, but it does have a significant success rate.
 - An attacker will walk *behind an employee that has legitimate access* and enter behind them by 1) borrowing their RFID card, or 2) gaining entry by using a fake card under the guise of accessibility problems.

Internal Reconnaissance

Internal Reconnaissance

- Unlike external reconnaissance, internal reconnaissance is done on-site.
- Attacks are carried out within an organization's network, systems and premises.
- Mostly, this process is aided by software tools.
- An attacker interacts with the actual target systems to find out information about its vulnerabilities.
 - The main difference between external and internal reconnaissance: External reconnaissance is done without interacting with the system, but by instead finding entry points through humans that work in the organization.

Internal Reconnaissance

- The main target is the internal network of an organization,
 - Hackers are sure to find the data servers and the IP addresses of hosts they can infect.
- Attackers use networks to discover and analyze potential targets to attack in the future.
- Internal reconnaissance is used to determine the security mechanisms in place that ward off hacking attempts.
- Many cyber security tools have been made to mitigate software used to perform reconnaissance attacks.
- Lack of the installation of enough security tools, hackers can still find ways to hack through the already-installed ones.

Internal Reconnaissance

- Sniffing and Scanning
 - Terms used in network that generally refer to the act of eavesdropping on traffic in a network.
 - Enable attackers and attackers know exactly what is happening in a network.
- Sniffing tools:
 - are designed to capture the packets being transmitted over a network and to perform analysis on them.
 - E.g., Prismdump, tcpdump, Nmap, Wireshark, Scanrand, Cain and Abel....
- Packet Analysis is essential to perform internal reconnaissance.

Sniffing and Scanning Tools

- Prismdump
 - Designed only for Linux, this tool allows hackers to sniff with Prism2 chipset-based cards.
 - Only capturing packets and storing it to `pcap` format.
- Tcpdump
 - the most powerful packet-filtering capabilities and can even selectively capture packets.
- Wireshark
 - Most popular sniffing tools with a user-friendly interface and powerful packet interpretation.

Sniffing Tools

- Nmap

- Attackers will try to map out the hosts in a network in order to discover the ones that contain valuable information.
- The hackers use slower scanning tools that get past all network monitoring systems. The monitoring tools will not detect the scanning activity.

- Nessus

- The known best network scanners and vulnerability scanner for white hats.
- It scans a network and shows connected devices that have misconfigurations and missing patches.
- The tool shows the devices that are using their default passwords, weak passwords, or have no passwords at all and recovers passwords from some devices by launching an external tool to help it with dictionary attacks against targets in the network.
- Lastly, the tool is able to show abnormal traffic in the network.
- Example of the report (https://virginia.service-now.com/its?id=itsweb_kb_article&sys_id=75e70054dbb553404f32fb671d9619d5)

Conclusion

- At the end of both stages of reconnaissance, attackers will have enough information to proceed or cancel a cyber-attack.
- From an external reconnaissance,
 - they will know the behavior of users and use it to an organization's disadvantage.
- Internal reconnaissance,
 - will enable attackers to learn more about the network in question.
- At the end of this stage, attackers are then able to engage an organization on two fronts: either from the users' side or internally from the network's vulnerabilities.

Compromising the System

Current Trends

- Hackers can be persistent, more creative, and increasingly sophisticated with their attacks. → Hacking techniques become more sophisticated each year.
- Current trends in terms of the preferred attacks and modes of execution includes following:
 - **Extortion attacks**
 - **Data manipulation attacks**
 - **Backdoors**
 - **IoT device attacks**
 - **Mobile device attacks**
 - **Hacking every devices**
 - **Hacking the cloud**

Extortion Attacks

- Extorting money directly from their victims
 - Holding computer files for *ransom*
 - Threatening to *release damaging information* about a victim to the public
- Ransomware
 - WannaCry
 - ✓ The hacker asks for \$300 within 72 hours through Bitcoin address.
 - ✓ The money becomes double and permanently locked after 7 days.
 - ✓ WannaCry reportedly only made \$50,000 since a kill switch was discovered.
- Extorting money by threatening to hack sites
 - The Ashley Madison incident
 - ✓ After failed extortion attempts, hackers exposed the user data of millions of people.
 - ✓ The company offered to pay a total of \$11 million to compensate for the exposure of 36 million users.

Extortion Attacks

- Extorting money by threatening to hack sites (Another case)
 - United Arab Emirates bank (2015)
 - ✓ The hacker held the user *data to ransom* and demanded a payment of \$3 million from the bank.
 - ✓ The company did not accept the hackers' offer. → The user data which contained personal details of the account owners, their transactions, and details of the entities that they had transacted with was released to the public.
- Logistically, this is viewed as *simpler than trying to sell off stolen data to third parties.*
- Hackers are also able to negotiate for more money if *the data they hold is more valuable to owners than it is to third parties.*

Data Manipulation Attacks

- Hackers *compromise systems through the manipulation of data* instead of deleting or releasing it. → *It is difficult to detect.*
- The hacker changes just a single value, but the consequences can be far-reaching.
- The next stage of cybercrime, and it is anticipated that there will be *many more cases of it in the near future.*

Data Manipulation Attacks

- The manipulation can happen on *health care, financial, and government data* which were reported to be compromised by the hackers.
- A slight escalation of these attacks would have greater consequences
 - For example, **in a bank, the data manipulation is catastrophic.**
 - ✓ Withdrawals could be suspended, and it would take the bank months, or even years, to determine the actual customer balances.

Data Manipulation Attacks

- Data manipulation attacks could also be used *to provide misinformation to the masses*:
 - E.g. hackers were able to hack into the official Twitter account of The Associated Press and tweet a news story that the Dow had dropped by 150 points (Deflation of the Dow by an estimated \$136 billion).
 - As seen, this is an attack that can affect any company and hurt its profits.
- Many people who have motives, especially competitors, to bring down other companies in whichever way possible.

Backdoors

- In 2016, one of the leading network device manufacturers, Juniper Networks, found that some of its firewalls had firmware that contained backdoors installed by hackers. *The backdoors enabled hackers to decrypt traffic flowing through the firewalls.*
- The *National Security Agency (NSA)* was put in the spotlight since the backdoor had similarities to another one that was also attributed to the agency. Although it is unclear who was actually responsible for the backdoor, the incident brings up a big threat.
- Since these types of backdoor are hard to find, it is expected that they will be extensively used by hackers in the near future.

Attacks on IoT Device

- The attacks using **Internet of Things (IoT)** devices available, from smart home appliances to baby monitors.
- The ***Mirai* (未来) attack** was aimed at commandeering large networks made up of IoT devices to generate **vast illegitimate traffic** to take down the servers (This type attack is called distributed denial of service (DDoS))
- IoT devices are easier to access, are already available in large numbers, and are **not adequately protected**.
 - **Manufacturers** of IoT products have not been prioritizing the security of their devices.
 - Users are lazy, and experts say that most users leave IoT devices ***with their default security configurations***.

Mobile Device Attacks

- Gradual increase in malicious activity targeting mobile devices
 - 9 Million attacks blocked (2015) → 18 Million attacks blocked (2016)
- A mobile malware aims to
 - **Send messages** on victim's phones to generate revenues for hackers.
 - **Steal personal information** from their victims' devices.
- Most smartphone users are unconcerned about attacks that hackers can carry out on their devices.
- Smartphones have browsers and web-supported apps
 - Vulnerable to scripting attacks
 - Exploitable through the man-in-the-middle attack.
- Example of Smartphone Malwares: BlueBorne (September 2017)

Hacking Every Device

- Targeting non-obvious devices, which is *seemed to be harmless*, in corporate networks.
- In particular, **printers**: Since modern printers come with an inbuilt memory function and only basic security features. Accessing to the printer may reveal the following:
 - **Password** authentication mechanisms
 - Gathering the **sensitive data** that users send to be printed
 - Used as **entry points** into otherwise secure networks
- Examples: “Weeping Angel” in WikiLeaks
 - Exploiting the *always-on voice command system of Samsung smart TVs*
 - Spying on people in a room by recording their conversations
 - Transmitting the conversation of viewers to a **CIA** server.

Hacking the Clouds

- Clouds are one of the fastest growing technologies today.
 - Clouds offer flexibility, accessibility, and capacity to the company's IT system.
- One great vulnerability in the cloud: everything - storage space, CPU cores, and network interfaces, is shared.
- Hackers try to go beyond the boundaries that cloud vendors have established for each user.
- Security majorly left to the cloud vendor:
 - The **security environment** of the cloud is largely determined by the vendor.
 - *The security control of the individual company is limited.*
 - The use of shared platforms with other people.
- There has been an *upward growth of incidences* of cloud vendors and companies using the cloud being attacked.

Hacking the Clouds

- The cloud was **not the direct target**: hackers had to compromise a user or a system within an organization.
- Examples:
 - **Target**: The credit card details of up to 70 million customers of Target were stolen. It was started from a phishing email, but *the data in the cloud server* were leaked to the hacker.
 - **Home Depot**: the details of about 56 million credit cards and 50 million emails belonging to clients were compromised. The hacker used a malware to infect *a point of sale cloud system*.
 - **Sony Pictures**: the attackers were able *to obtain from the organization's cloud servers* employee information, financial details, sensitive emails, and even unreleased films.
 - The US Internal Revenue Service (**IRS**): The details of more than 100,000 accounts from IRS were stolen from the *cloud server*.